LAB DE DÉTECTION D'INTRUSION

Rapport Final — Projet 01

Hyper-V / Debian / Wazuh 4.9.2 + Zabbix 8.0

Auteur	Styve Landry SIME KOUNOU
Contact	styvelandry1@outlook.fr
Projet	01 — Lab de Détection d'Intrusion
Période	Septembre — Octobre 2026
Environnement	Hyper-V / Windows 11 Pro / Réseau Lab-Isolé 192.168.100.0/24
Cible	DVWA — Damn Vulnerable Web Application v1.10
Outils offensifs	Nmap · Hydra · SQLmap (depuis Kali 192.168.100.40)
Outils défensifs	Wazuh 4.9.2 · Zabbix 8.0
Résultat clé	Brute force SSH détecté rule 5712 level 10 — Délai Nmap : 3min 42sec

1. Résumé exécutif

Ce document présente le bilan complet du Projet 01, consacré à la mise en place d'un laboratoire de détection d'intrusion monté de bout en bout sur un hyperviseur Hyper-V sous Windows 11 Pro. L'idée de départ était simple : déployer une infrastructure de surveillance réaliste, la soumettre à des attaques contrôlées, puis mesurer concrètement ce que les outils de sécurité sont capables de détecter — et dans quel délai.

Trois scénarios d'attaque distincts ont été exécutés depuis une machine Kali Linux (192.168.100.40) contre une cible DVWA volontairement vulnérable (192.168.100.30) : une reconnaissance réseau complète via Nmap, une attaque par dictionnaire sur SSH avec Hydra, et une injection SQL automatisée avec SQLmap. Wazuh 4.9.2 assurait la détection comportementale par analyse de logs, tandis que Zabbix 8.0 supervisait l'infrastructure en temps réel (CPU, disponibilité, réseau).

Les résultats ont dépassé les attentes initiales. Wazuh a déclenché sa première alerte seulement 3 minutes et 42 secondes après le lancement du scan Nmap (rule 510, level 7). L'attaque Hydra a généré 135 tentatives de connexion SSH, toutes captées et corrélées par la rule 5712 niveau 10 — confirmation de brute force. L'injection SQL sur DVWA a exposé cinq comptes utilisateurs avec leurs condensats MD5, classifiée en gravité critique. Au total, six tactiques MITRE ATT&CK ont été identifiées dans les logs.

> ℹ️ **Points clés**
> Nmap → 1ère alerte Wazuh en 3 min 42 sec
> 135 tentatives SSH détectées (rule 5712 level 10)
> 5 comptes extraits par SQLmap
> 6 tactiques MITRE ATT&CK corrélées

2. Architecture du lab

Le lab repose entièrement sur Hyper-V, la solution de virtualisation intégrée à Windows 11 Pro. Quatre machines virtuelles ont été déployées sur un réseau interne isolé nommé « Lab-Isolé », adressé en 192.168.100.0/24. Le PC hôte (LANDRY-SK) fait office de passerelle NAT pour les accès sortants ponctuels vers Internet (téléchargement des paquets lors de l'installation), tout en maintenant l'isolation complète du réseau de test pendant les phases d'attaque.

2.1 Tableau des machines virtuelles

VM	IP	OS	Rôle	Ports exposés
VMServerWazuh	192.168.100.60	Debian 12	Wazuh all-in-one	443, 1514, 1515, 55000
VMZabbix	192.168.100.50	Debian 13	Zabbix 8.0	8080, 10051, 10050
debian-cible	192.168.100.30	Debian 13	DVWA + agents	80, 10050, 1514
Kali	192.168.100.40	Kali Linux	Machine attaquante	—

2.2 Réseau et isolation

Le switch virtuel interne a été configuré pour simuler un réseau d'entreprise isolé. La commande PowerShell New-VMSwitch a créé l'interface LAN Lab-Isolé, et le NAT a été activé côté hôte uniquement pour la phase d'installation. Une fois tous les paquets installés, les tests de ping vers 8.8.8.8 depuis les VMs ont confirmé l'absence de connectivité Internet — condition indispensable pour que les attaques ne sortent pas du périmètre du lab.

3. Mise en place de l'environnement

3.1 Wazuh 4.9.2 — Déploiement all-in-one

Wazuh a été installé en mode all-in-one sur la VM VMServerWazuh (Debian 12, 192.168.100.60). Cette configuration regroupe en un seul nœud le Wazuh Manager (moteur d'analyse des règles), le Wazuh Indexer (OpenSearch pour le stockage et la recherche), le Dashboard (interface web Kibana-like), et Filebeat (transport des logs). L'accès au tableau de bord se fait via HTTPS sur le port 443.

3.2 Déploiement et enrôlement de l'agent Wazuh

Sur la machine cible (debian-cible, 192.168.100.30), l'agent Wazuh a été installé et enregistré auprès du manager. La commande /var/ossec/bin/agent-control -i 001 a confirmé l'enrôlement de l'agent avec l'identifiant 001. Le tableau de bord affiche ensuite l'agent debian-cible avec le statut « actif » en temps réel.

3.3 Zabbix 8.0 — Supervision infrastructure

Zabbix 8.0.0beta2 a été installé sur la VMZabbix (Debian 13, 192.168.100.50), accessible via le port 8080. Dès l'installation, la vue globale ne montrait qu'un seul hôte — le Zabbix Server lui-même. L'agent Zabbix a ensuite été déployé sur debian-cible, qui est apparu comme deuxième hôte supervisé avec 214 éléments de collecte et 103 déclencheurs actifs.

3.4 DVWA — Cible vulnérable

DVWA (Damn Vulnerable Web Application v1.10) a été déployée via Docker sur debian-cible. Le service Docker est démarré automatiquement au boot, et DVWA est accessible sur le port 80 de la machine cible. Pour les tests d'injection SQL, le niveau de sécurité de DVWA a été positionné en « Low » — aucune protection active, ce qui représente le scénario le plus défavorable côté défense.

4. Chronologie des attaques

4.1 Phase 1 — Reconnaissance réseau (Nmap)

La phase de reconnaissance a démarré le 2 octobre 2026 à 02h43, heure locale. Depuis Kali Linux (192.168.100.40), un scan complet de la cible a été lancé avec les options -sV (détection de version), -sC (scripts NSE par défaut), -O (empreinte OS) et -p- (tous les 65535 ports). Le résultat a été sauvegardé dans /root/scan_cible.txt pour archivage.

```
sudo nmap -sV -sC -O -p- 192.168.100.30 -oN /root/scan_cible.txt
```

Trois services ont été identifiés : SSH sur le port 22 (OpenSSH 10.0p2 Debian), HTTP sur le port 80 (Apache 2.4.25 hébergeant DVWA v1.10), et un agent Zabbix sur le port 10050. L'absence de réponse

ping n'a pas gêné le scan TCP, et Nmap a récupéré l'adresse MAC (00:15:5D:5E:CC:37 Microsoft) confirmant qu'il s'agit d'une VM Hyper-V.

Port	Protocole	Service	Version
22/tcp	SSH	OpenSSH	10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp	HTTP	Apache	2.4.25 — DVWA v1.10 (login.php)
10050/tcp	TCP	Zabbix	tcpwrapped — Agent Zabbix visible

4.2 Phase 2 — Brute force SSH (Hydra)

Le 3 octobre 2026 à 22h56, une attaque par dictionnaire a été lancée sur le service SSH de la cible avec Hydra. La liste rockyou.txt (14 millions de mots de passe) a été utilisée, avec 4 threads parallèles et le mode verbose activé pour tracer chaque tentative. L'utilisateur ciblé était « user3 », compte fictif créé spécifiquement pour le test.

```
hydra -l user3 -P /usr/share/wordlists/rockyou.txt ssh://192.168.100.30 -t 4 -V
```

En l'espace de quelques minutes, 135 tentatives de connexion ont été générées. Wazuh les a toutes capturées via l'analyse des logs /var/log/auth.log de la cible, remontant progressivement du level 5 (rule 5710 — utilisateur inexistant) jusqu'au level 10 (rule 5712 — confirmation de brute force SSH). Le seuil de détection a été franchi en moins de 10 minutes après le début de l'attaque.

4.3 Phase 3 — Injection SQL sur DVWA (SQLmap)

Le 4 octobre 2026 vers 01h00, l'attaque par injection SQL a été réalisée avec SQLmap 1.10.9 contre le paramètre id de la page /vulnerabilities/sqli/ de DVWA. L'authentification sur DVWA a d'abord été effectuée via curl pour récupérer le cookie de session, qui a ensuite été transmis à SQLmap.

```
curl -c /tmp/dvwa_cookie.txt -d
"username=admin&password=password&Login=Login" \
     http://192.168.100.30/login.php

sqlmap -u "http://192.168.100.30/vulnerabilities/sqli/?id=1&Submit=Submit" \
       --load-cookies=/tmp/dvwa_cookie.txt --dbs --batch --level=3
```

SQLmap a confirmé quatre types d'injection sur le paramètre id : booléenne, error-based, time-based blind et UNION query. La base dvwa a été intégralement vidée : cinq comptes utilisateurs ont été extraits avec leurs condensats MD5 (admin, gordonb, 1337, pablo, smithy). Les hash MD5 sont cassables par dictionnaire en quelques secondes avec des outils courants.

5. Timeline des événements

Le tableau ci-dessous récapitule la chronologie complète des actions offensives et des alertes défensives correspondantes, avec les délais mesurés.

Date/Heure	Action	Outil	Alerte Wazuh	Level	Délai
02/10 02:43:00	Scan réseau complet	Nmap -sV -sC -O -p-	—	—	—
02/10 02:46:42	—	—	Rule 510 anomalie (×23)	7	3min 42sec
03/10 22:56:38	Brute force SSH (135 tent.)	Hydra rockyou.txt	Rule 5710 SSH inex. ×135	5	< 2min
03/10 ~23:06	—	—	Rule 5758 max auth	8	—
03/10 ~23:06	—	—	Rule 5712 brute force	10	< 10min
03/10 ~23:06	—	—	Rule 2502 pwd missed	10	—
04/10 ~01:00	Injection SQL DVWA	SQLmap --batch	Anomalies web	Cr.	—
04/10 ~01:10	—	—	5 comptes + hash MD5	Cr.	—

ℹ️ **Délai clé**
Nmap lancé à 02:43:00 → première alerte Wazuh rule 510 à 02:46:42 = 3 minutes 42 secondes.

6. Alertes Wazuh — Analyse des règles

6.1 Vue d'ensemble du tableau de bord

Après les trois phases d'attaque, le tableau de bord Wazuh affichait 26 alertes actives. La répartition par niveau de sévérité illustre bien la progression de la menace : des événements informatifs de niveau 3 liés aux sessions PAM jusqu'aux alertes critiques de niveau 10 confirmant le brute force SSH.

6.2 Preuve de détection Nmap (Chasse à la menace)

La vue « Chasse à la menace » (Threat Hunting) de Wazuh fournit la preuve chronométrée de la détection du scan Nmap. On y distingue clairement le groupe d'alertes rule 510 à 02:46:42 — soit 3 minutes et 42 secondes après le lancement du scan à 02:43:00. Au total, 23 événements ont été générés dans la fenêtre de 02:38 à 02:53.

6.3 Tableau récapitulatif des règles

Rule ID	Description	Level	Occurrences	Tactique MITRE
510	Événement de détection d'anomalie (Nmap)	7	23	—
5710	sshd: Login — utilisateur inexistant	5	135	Credential Access

Rule ID	Description	Level	Occurrences	Tactique MITRE
5503	PAM: Échec de connexion utilisateur	5	19	Credential Access
2502	Mot de passe manqué plus d'une fois	10	18	Credential Access
5758	Nombre max de tentatives d'auth dépassé	8	17	Credential Access
5712	sshd: Brute force SSH confirmé	10	9	Lateral Movement
5405	Tentative sudo non autorisée	5	1	Privilege Escalation
5501	PAM: Session ouverte	3	3	Valid Accounts
5715	sshd: Authentification réussie	3	2	Valid Accounts

6.4 Cartographie MITRE ATT&CK

Tactique	Technique	ID MITRE	Vecteur observé
Credential Access	Brute Force	T1110	Hydra SSH — 135 tentatives
Credential Access	Password Guessing	T1110.001	Dictionnaire rockyou.txt
Lateral Movement	Remote Services SSH	T1021.004	Tentatives via SSH sur port 22
Defense Evasion	Valid Accounts	T1078	Sessions PAM ouvertes (rule 5501)
Privilege Escalation	Sudo and Sudo Caching	T1548.003	Tentative sudo non autorisée
Initial Access	Exploit Public-Facing App	T1190	SQLi sur DVWA (4 vecteurs)

7. Supervision infrastructure — Zabbix 8.0

7.1 Vue globale en conditions d'attaque

Zabbix a supervisé debian-cible tout au long des phases d'attaque. La vue globale, capturée le 30 septembre 2026 à 13h09, montre un pic de CPU à 1,05% sur debian-cible — valeur bien au-dessus de la baseline habituelle (< 0,1%). Ce pic correspond à l'activité générée par le scan réseau. Les deux hôtes (debian-cible et Zabbix Server) restaient actifs, avec 214 éléments supervisés et 103 déclencheurs.

7.2 Rapport de disponibilité

Le rapport de disponibilité Zabbix confirme qu'aucun déclencheur d'alerte infrastructure n'a été activé de façon anormale sur toute la durée du projet. L'ensemble des triggers supervisés pour debian-cible affiche un taux de résolution de 100,0000% — ce qui signifie que la machine est restée pleinement opérationnelle malgré les attaques subies. Les attaques offensives n'ont pas causé d'interruption de service mesurable.

7.3 Complémentarité Wazuh / Zabbix

Les deux outils se complètent sans se chevaucher. Wazuh analyse les logs d'événements et corrèle les comportements suspects selon les règles de détection et le référentiel MITRE ATT&CK — c'est lui qui « voit » l'attaque. Zabbix, lui, mesure l'état de l'infrastructure : consommation CPU, disponibilité des services, trafic réseau. Ensemble, ils offrent une couverture SOC complète : détection comportementale + supervision d'impact système.

Outil	Rôle principal	Ce qu'il a détecté / mesuré
Wazuh 4.9.2	Détection comportementale (SIEM)	135 tentatives SSH, 9 rules déclenchées, 6 tactiques MITRE
Zabbix 8.0	Supervision infrastructure	Pic CPU 1,05% (scan), 100% disponibilité, 214 éléments

8. Résultats SQLmap — Injection SQL DVWA

⛔ **Vulnérabilité CRITIQUE**
Injection SQL confirmée sur paramètre id — 5 comptes extraits, hash MD5 compromis.

L'injection SQL sur DVWA a donné des résultats complets. SQLmap a identifié quatre techniques d'injection exploitables simultanément sur le paramètre id (GET) : injection booléenne, error-based, time-based blind et UNION query. Les deux bases de données exposées sont dvwa et information_schema.

Technique d'injection	Description
Booléenne	Réponse différente selon condition vraie/fausse
Error-based	Messages d'erreur MySQL révèlent la structure
Time-based blind	Délai conditionnel via SLEEP() — extraction aveugle
UNION query	Extraction directe de données par requête UNION

Les cinq comptes de la table dvwa.users ont été extraits avec leurs condensats MD5. L'algorithme MD5 est considéré comme obsolète pour le stockage de mots de passe : ces condensats peuvent être cassés par attaque dictionnaire en quelques secondes avec des outils comme hashcat ou john.

Compte	Hash MD5	Statut
admin	5f4dcc3b5aa765d61d8327deb882cf99	Compromis
gordonb	e99a18c428cb38d5f260853678922e03	Compromis
1337	8d3533d75ae2c3966d7e0d4fcc69216b	Compromis
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	Compromis

Compte	Hash MD5	Statut
smithy	5f4dcc3b5aa765d61d8327deb882cf99	Compromis

9. Recommandations de sécurité

Les trois vecteurs d'attaque testés révèlent des failles corrigeables avec des mesures techniques standard. Voici les recommandations classées par priorité.

Priorité	Recommandation	Description
Critique	Requêtes préparées (PDO/MySQLi)	Séparer le code SQL des données utilisateur — élimine l'injection SQL
Critique	Remplacement de MD5	Utiliser password_hash() / password_verify() (bcrypt ou Argon2)
Haute	Fail2ban sur SSH	Bloquer automatiquement les IPs après N échecs consécutifs
Haute	Désactivation SSH root	Interdire la connexion directe root (PermitRootLogin no)
Haute	Validation stricte des entrées	Rejeter toute valeur non numérique pour id ; listes blanches
Moyenne	Mise à jour OS et Apache	Debian 9 + Apache 2.4.25 sont obsolètes — migrer vers versions LTS
Moyenne	Réduction des privilèges SQL	Compte DB avec droits SELECT uniquement — pas d'accès information_schema
Surveillance	Maintien des règles Wazuh	Garder actives les rules 5712, 5758, 31103 — ne pas les désactiver

10. Conclusion

Ce projet a permis de mettre en place, de tester et de documenter un lab de détection d'intrusion fonctionnel, entièrement construit avec des outils open source. Trois vecteurs d'attaque réalistes ont été simulés, et les deux outils de surveillance ont rempli leur rôle : Wazuh a détecté chaque attaque avec des délais mesurés et documentés, Zabbix a mesuré l'impact sur l'infrastructure en temps réel.

Le résultat le plus marquant reste la rapidité de détection du scan Nmap : 3 minutes et 42 secondes séparent le lancement du scan de la première alerte rule 510 sur le tableau de bord. Sur une attaque par brute force SSH plus agressive (135 tentatives), la corrélation Wazuh a confirmé le brute force en moins de 10 minutes via la rule 5712 au niveau 10.

Ce lab est dimensionné pour un usage pédagogique, mais les enseignements sont directement transposables : les règles Wazuh, les tactiques MITRE ATT&CK identifiées et les métriques de délai de détection sont les mêmes que ceux utilisés dans un environnement SOC de production. La documentation de ce projet constitue une base solide pour toute démarche de mise en conformité ou d'audit de sécurité.

Compétences démontrées

- Déploiement d'une infrastructure de supervision sécurité (Wazuh 4.9.2 + Zabbix 8.0) sur Hyper-V
- Configuration et gestion d'agents sur VMs Linux (Debian 12 et Debian 13)
- Exécution d'un scénario d'attaque contrôlé et documenté (Nmap · Hydra · SQLmap)
- Analyse d'alertes avec corrélation MITRE ATT&CK — 6 tactiques identifiées sur 9 règles
- Rédaction d'un rapport d'incident format SOC avec timeline chronométrée
- Mesure quantitative du délai de détection : 3min 42sec (Nmap) | < 10min (Hydra brute force)

Contact : styvelandry1@outlook.fr